Федеральное государственное автономное образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность

Работа 2
Анализ и устранение уязвимости на примере реального CVE с использованием Docker

Евстигнеев Никита Артёмович
Группа P3431

Практик: Рыбаков Степан Дмитриевич

2026

1. Уязвимость и контролируемый стенд

Цель: воспроизвести известную уязвимость, объяснить причину и проверить устранение без нарушения обычной работы сервиса.

CVE-2021-43798: обход каталога (directory traversal, CWE-22) в Grafana версий 8.0.0-beta1 - 8.3.0. Обработчик статических файлов плагина позволяет неаутентифицированному пользователю выйти за пределы каталога плагина и прочитать произвольные файлы, доступные процессу Grafana, по пути вида /public/plugins/<id_плагина>/<обход>. Исправлено в 8.3.1.

CVSS 3.1: 7.5 HIGH (источник security-advisories@github.com, тип Secondary).

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`

Вектор C:H/I:N/A:N отражает высокое влияние на конфиденциальность (чтение произвольных файлов) без прямого влияния на целостность и доступность. Атака не требует аутентификации и взаимодействия пользователя. Источник сохранён в evidence/nvd-CVE-2021-43798.json.

Контейнер	Версия / адрес	Назначение
vulnerable	Grafana 8.3.0 127.0.0.1:18083	Воспроизведение исходной ошибки
fixed	Grafana 8.3.1 127.0.0.1:18084	Контроль исправленной версии

Использованы официальные образы grafana/grafana. В оба контейнера только для чтения смонтирован специально подготовленный учебный файл /tmp/lab2-proof.txt без персональных данных; именно он читается при проверке вместо конфигов и паролей. Контейнеры опубликованы только на loopback 127.0.0.1; проверка не обращается к внешним адресам и не читает файлы хоста.

Причина в исходном коде

Маршрут отдачи ресурсов плагина брал имя файла из URL и соединял его с каталогом плагина без очистки и нормализации сегментов «../». Выход за пределы базового каталога не проверялся, поэтому последовательности «../» уводили чтение вверх по файловой системе. В качестве точки входа используется штатный встроенный плагин alertlist; сторонние плагины не устанавливались.

Это дефект кода обработки пути, доступный без аутентификации. Исправление в 8.3.1 добавляет очистку и проверку запрошенного пути, поэтому тот же запрос возвращает отказ.

2. Воспроизведение и применение исправления

Последняя фактическая проверка: 25.10.2026 17:29 МСК. Запуск выполнен из корня проекта:

```
docker compose -f lab2/compose.yaml up -d
python3 lab2/demo.py
```

demo.py вызывает verify.py. В нём зафиксированы два localhost-порта (18083 - уязвимый, 18084 - исправленный); он отправляет одинаковые запросы в оба контейнера, проверяет версию через /api/health, код ответа и содержимое, затем сохраняет results.json.

Запрос из выполненной проверки

```
GET /public/plugins/alertlist/../../../../../../../../../../../../tmp/lab2-proof.txt
```

Клиент http.client сохраняет заданный путь без нормализации на стороне клиента. При демонстрации через curl нужен --path-as-is, иначе «../» могут быть свёрнуты до отправки. Путь обращается только к подготовленному файлу /tmp/lab2-proof.txt.

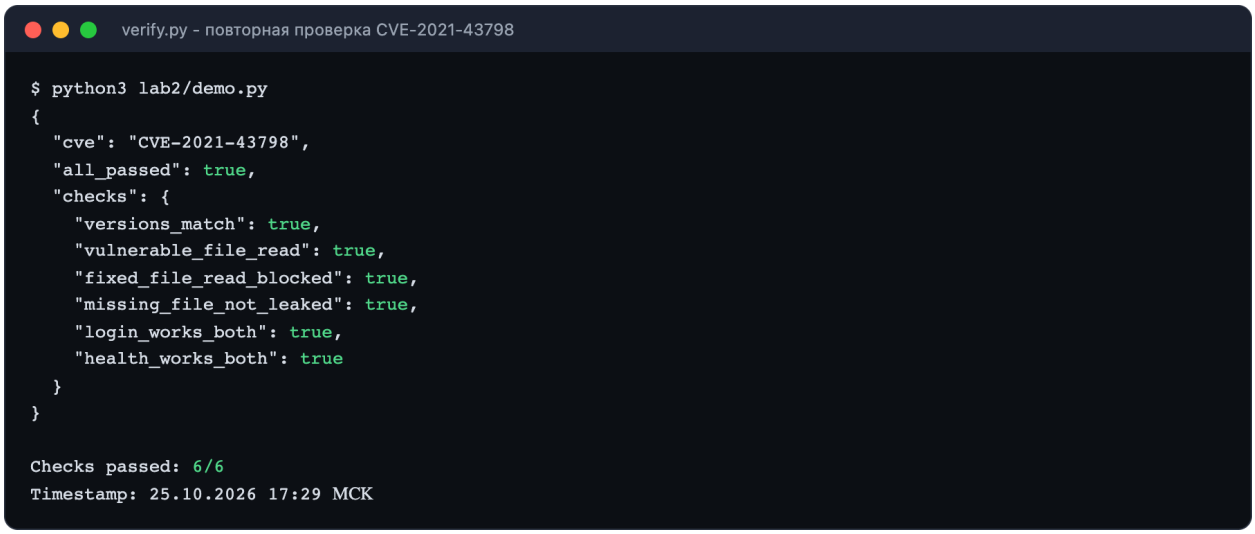


Рисунок 1. Вывод verify.py: все шесть проверок пройдены.

Применённое изменение

Исправление - обновление базового образа Grafana с уязвимого 8.3.0 на 8.3.1 (официальный патч безопасности). Сравнение выполняется двумя отдельными сервисами Compose, поэтому один и тот же запрос можно повторить рядом. Прочие условия одинаковы в обоих контейнерах, поэтому различие вызвано именно версией.

Для современного развёртывания нужны актуальная поддерживаемая версия Grafana, запуск от непривилегированного пользователя и ограничение доступных процессу файлов.

3. Верификация и выводы

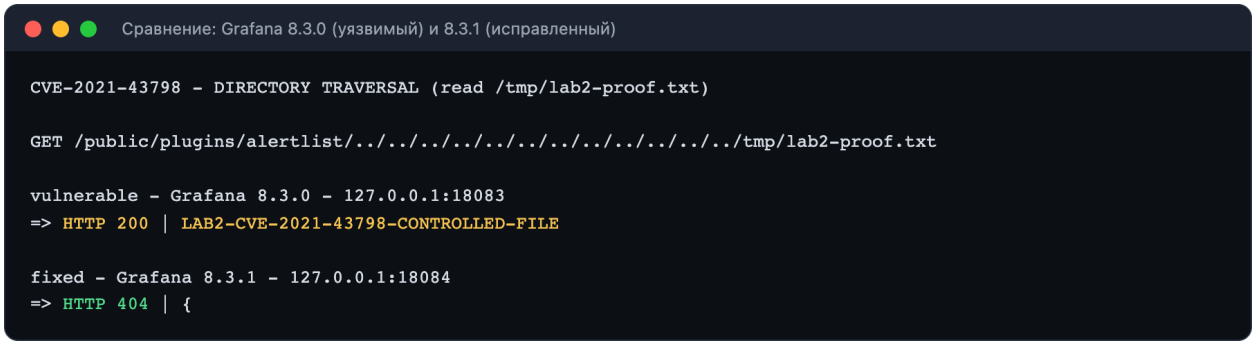


Рисунок 2. Сравнение HTTP-ответов: уязвимая версия читает файл по обходу каталога, исправленная отклоняет тот же запрос.

Проверка	Grafana 8.3.0	Grafana 8.3.1
Версия (/api/health)	8.3.0	8.3.1
Обход каталога → файл	HTTP 200; маркер файла получен	HTTP 404; содержимого файла нет
Несуществующий файл	HTTP 404; не раскрыт	HTTP 404; не раскрыт
Обычный вход /login	HTTP 200; работает	HTTP 200; работает

Полученный маркер подтверждает чтение файла за пределами каталога плагина. В исправленной версии тот же запрос возвращает отказ и не выдаёт содержимого; обычный вход /login в обеих версиях отвечает 200 - это регрессионная проверка, что исправление не сломало штатную работу. Читался только подготовленный файл; конфигурация и пароли Grafana не запрашивались.

Контрольные вопросы

Зачем Docker? Он даёт воспроизводимое изолированное окружение и позволяет удалить учебный сервис, не ставя уязвимую версию на хост. Изоляция не абсолютна: здесь дополнительно ограничена публикация портов только на loopback.

Уязвимость и эксплойт: уязвимость - дефект обработки пути ресурсов плагина; эксплойт - конкретный запрос с «../», использующий этот дефект для чтения файла.

Зачем регрессионная проверка? Запретить всё можно и отключением сервиса. Ответ 200 на /login подтверждает, что после обновления штатная работа сохранилась.

Зачем специалисту воспроизводить CVE? Чтобы проверить условия эксплуатации, обоснованно оценить последствия, распознать признаки в журналах и подтвердить исправление.

Вывод: все шесть проверок успешны. В исправленной версии именно проверенные запросы больше не срабатывают; полный аудит всех уязвимостей версии не проводился.

Источники

NVD: CVE-2021-43798; Grafana Security Release 8.3.1; GHSA-8pjx-jj86-j47p; NVD API (CVSS).